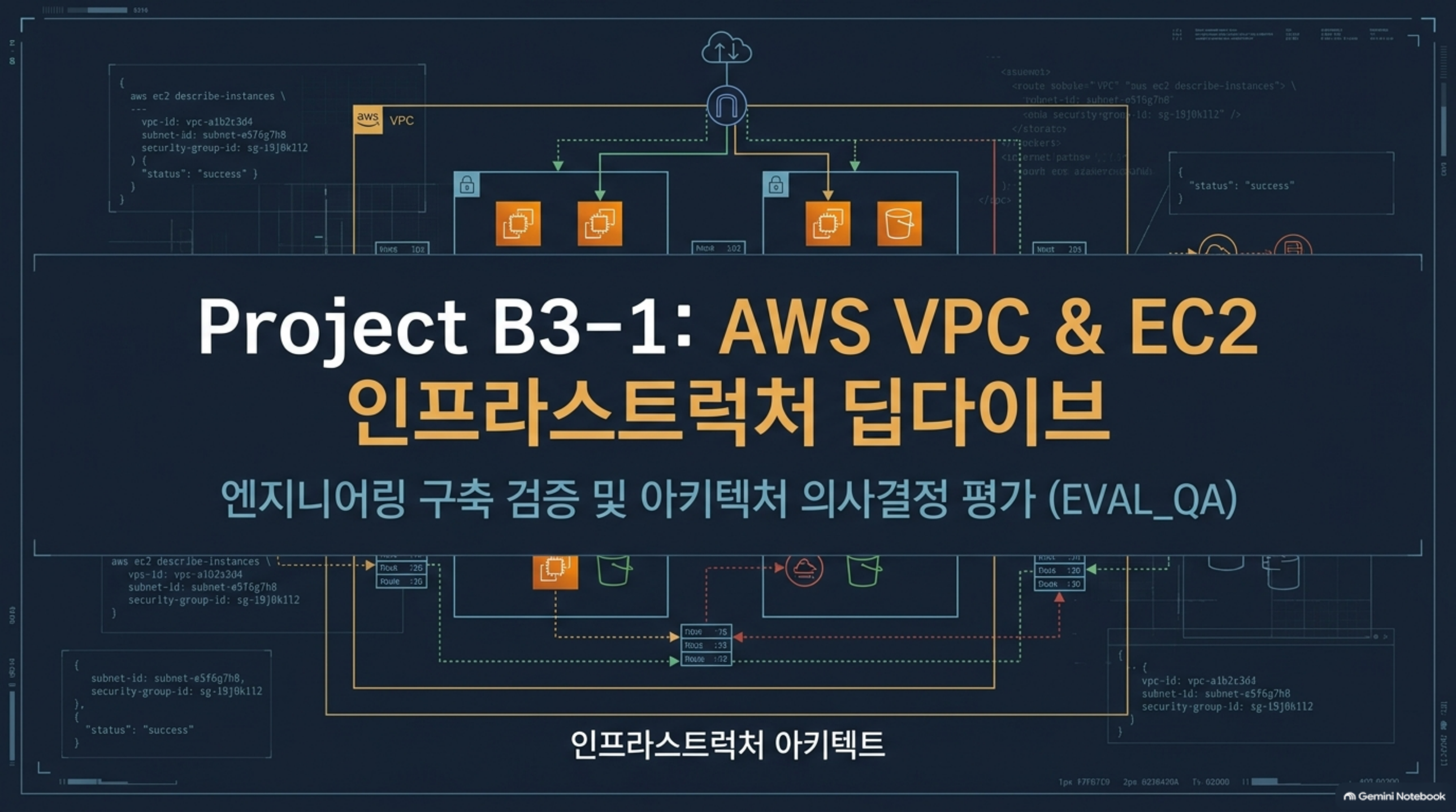


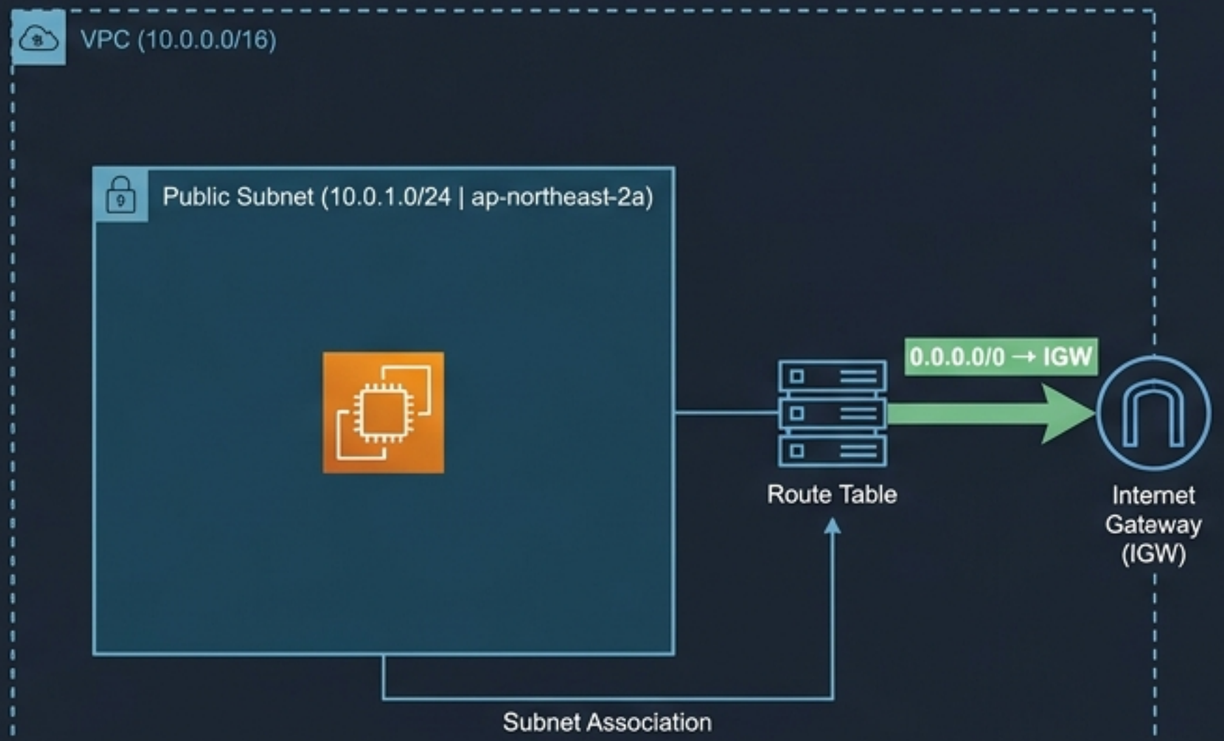
Project B3-1: AWS VPC & EC2 인프라스트럭처 딥다이브

엔지니어링 구축 검증 및 아키텍처 의사결정 평가 (EVAL_QA)

인프라스트럭처 아키텍트

Gemini Notebook

[Q1-1] VPC, Public Subnet, Internet Gateway, Route Table(0.0.0.0/0 → IGW)이 구성되어 있는가?

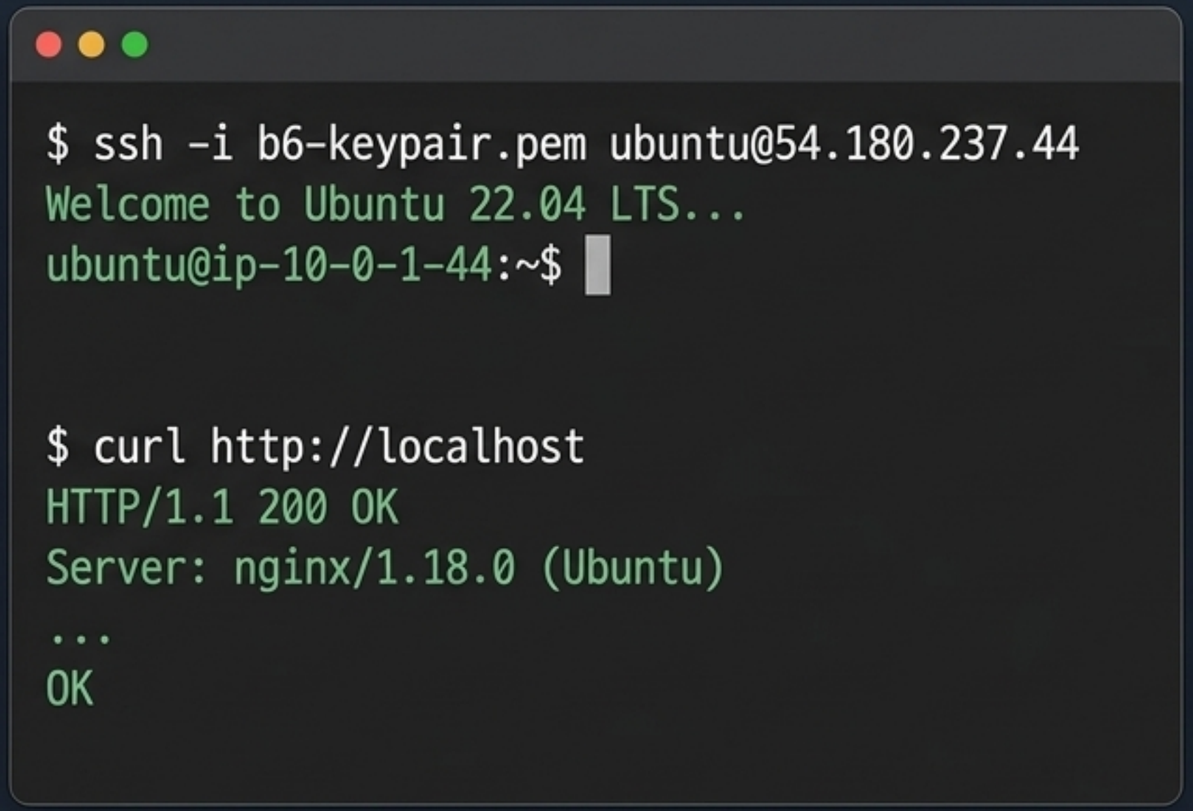


- **VPC 구성**
  ID: vpc-023d852a3471ef158
  CIDR: 10.0.0.0/16 (65,536개 사설 IP 공간 확보)
- **Public Subnet**
  ID: subnet-01c319e79337bc3b0
  영역: ap-northeast-2a
  속성: MapPublicIpOnLaunch=true
- **인터넷 관문 (IGW)**
  ID: igw-0216170a9e1876f6f
  상태: VPC Attached 완료
- **Route Table**
  ID: rtb-05896b293836ba38e
  연결: 서브넷 명시적 연결
  경로: 0.0.0.0/0 라우팅으로 외부 통신 개방

Gemini Notebook

[Q1-2] EC2에 SSH로 접속 가능하며, 웹 서버가 실행 중인가?

VISUAL EVIDENCE



TECHNICAL NARRATIVE

- **인스턴스 스펙**
  ID: i-05d106a3c3409edd4
  타입: t3.micro
  OS: Ubuntu 22.04 LTS
- **네트워크 할당**
  퍼블릭 IP: 54.180.237.44 (자동 부여)
- **접속 검증**
  키페어: b6-keypair.pem (권한 400)
  결과: SSH 원격 접속 **성공**
- **웹 서버 가동**
  프로비저닝: user-data.sh 자동 설치
  프로세스: systemctl enable --now nginx
  구동 **완료**

Gemini Notebook

[Q1-3] 보안 그룹 인바운드가 "필요 포트만" 허용하며, SSH(22)가 특정 IP로 제한되어 있는가?

VISUAL EVIDENCE

TECHNICAL NARRATIVE

- 보안 그룹 ID (Security Group ID)
  `sg-06a53efc080f4c3c6`
- 점검 방법 1: AWS 콘솔 시각적 점검
  EC2 > 보안 그룹(Security Groups) 메뉴에서 대상 그룹 선택 후 인바운드 규칙 탭 확인.
  HTTP(80): 소스 0.0.0.0/0 (전체 공개) 설정 확인.
  SSH(22): 소스가 0.0.0.0/0이 아닌 작업자의 특정 IP (/32)로 엄격히 제한 확인.
  성공 확인: 포트 22 소스에 개인 IP만 명시되고 광역 허용 없음.
- 점검 방법 2: AWS CLI를 통한 조회
  명령어 실행: `aws ec2 describe-security-groups --group-ids <보안-그룹-ID>`
  성공 확인: IpPermissions JSON 블록 내:
  FromPort: 80의 IpRanges가 0.0.0.0/0.
  FromPort: 22의 IpRanges가 본인 공인 IP (/32)로 설정.

Gemini Notebook

[Q1-4] 외부 접속이 아래 방식 중 1개로 검증되는가?

VISUAL EVIDENCE

```
$ curl -i -s http://54.180.237.44/health
HTTP/1.1 200 OK
Server: nginx/1.18.0 (Ubuntu)
Content-Type: text/plain
Content-Length: 2

OK
```

TECHNICAL NARRATIVE

- 검증 방식 선택
  방식 B (API 엔드포인트 헬스체크) 적용
- 대상 주소
  http://54.180.237.44/health
- 상태 검증 완료
  HTTP 응답 코드 200 OK 확인
  바디 문자열 'OK' 고정 출력 확인
- 엔지니어링 의의
  단순 HTML 파일 로딩보다 CI/CD 파이프라인 및 로드밸런서(ALB)의 자동화 검증(Health Check)에 더 적합한 클라우드 표준 방식.

Gemini Notebook

[Q1-5] 리소스 정리 체크리스트에서 최소 5종(EC2/EBS/EIP/IGW/VPC) 정리 완료를 확인할 수 있는가?

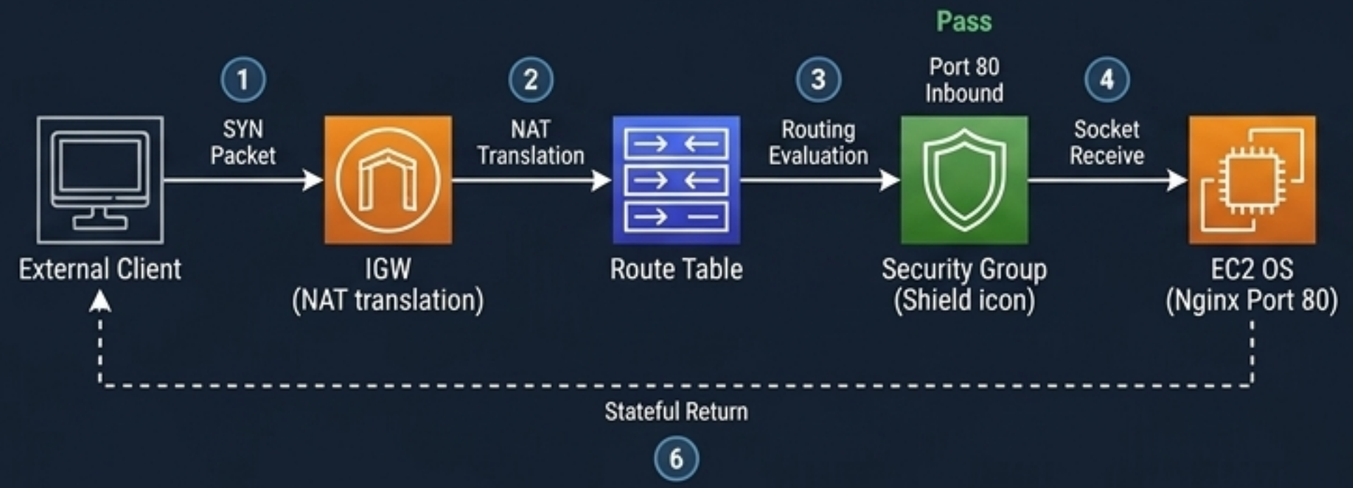
VISUAL EVIDENCE

TECHNICAL NARRATIVE

- **의존성 기반 역순 삭제**
  DependencyViolation 에러 방지를 위한 체계적인 하향식 리소스 정리 전략.
- **EC2 & EBS**
  terminate-instances 실행 완료.
  잔여 EBS(gp3) 볼륨 미존재 필터 조회 확인.
- **EIP**
  미사용 할당 EIP 반환 완료 확인 (상태: []).
- **네트워크 계층**
  IGW를 분리(detach)한 후 삭제.
  Subnet 및 Route Table 연계 해제.
- **최종 격리망 철거**
  delete-vpc 명령을 통해 실습 격리망 완전 철거 완료.
  은닉된 요금 발생 원천 차단.

[Q2-1] "외부 → IGW → Subnet → EC2"로 이어지는 네트워크 흐름을 다이어그램 기준으로 설명할 수 있는가?

VISUAL EVIDENCE



TECHNICAL NARRATIVE

- **1~2. 인입 및 NAT 변환**
  외부 클라이언트의 SYN 패킷이 IGW 도착.
  퍼블릭 IP를 프라이빗 IP(`10.0.1.x`)로 1:1 NAT 변환.

- **3. 라우팅 평가**
  Route Table이 대상 서브넷(`10.0.1.0/24`)으로 트래픽을 정확히 라우팅.

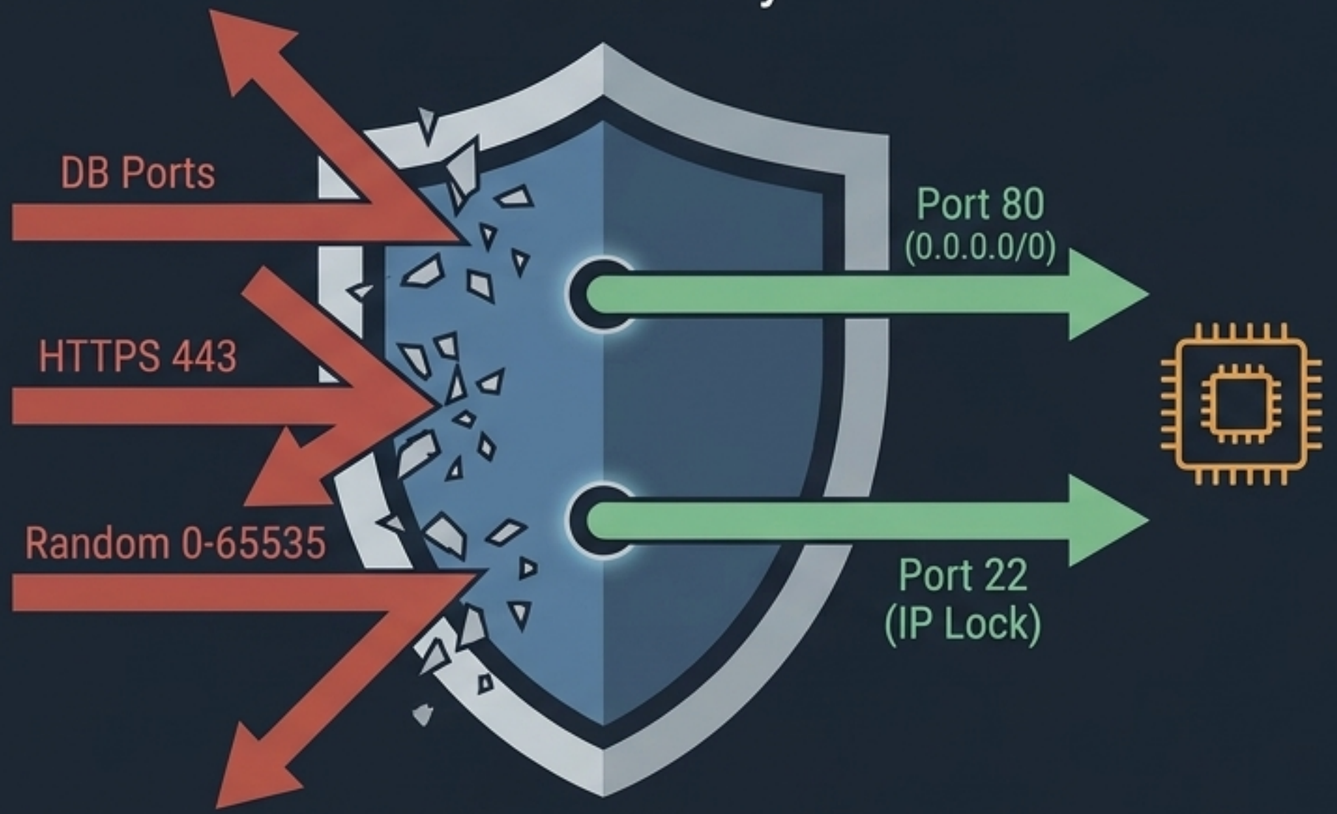
- **4~5. 보안 검사 및 수신**
  ENI 도달 직전 Security Group이 Port 80 인바운드 규칙 검사 (Pass).
  Ubuntu 커널을 거쳐 Nginx 소켓으로 수신.

- **6. Stateful 회신**
  응답 트래픽은 보안 그룹의 상태 저장(Stateful) 특성으로 인해 아웃바운드 규칙과 무관하게 자동 통과하여 클라이언트 도달.

Gemini Notebook

[Q2-2] 보안 그룹 규칙을 어떤 기준으로 최소화했는지(허용/미허용 포트) 설명할 수 있는가?

VISUAL EVIDENCE



TECHNICAL NARRATIVE

- **대원칙: Default Deny (기본 거부)**
  명시적으로 허용된 트래픽을 제외한 모든 패킷을 원천 차단하는 Zero Trust 원칙 적용.

- **포트 개방의 엄격한 근거**

  Port 443 (미허용): 본 실습 스코프에 SSL/TLS 인증서가 미포함되므로 불필요한 공격 표면 축소를 위해 차단.

  DB 및 내부 관리 (미허용): 3306, 5432, 8080 등 외부에 노출될 이유가 없는 포트 일체 차단.

  0-65535 포트 (절대 불가): 백도어 침해 및 횡적 이동 예방을 위해 전체 개방 엄격 금지.

- **필요 최소한의 개방**
  대민 웹 서비스(80) 및 철저히 통제된 관리자 터미널(22)만 예외 허용.

Gemini Notebook

[Q2-3] 외부 접속 검증을 A 또는 B 중 무엇으로 선택했고, 구성을 설명할 수 있는가?

VISUAL EVIDENCE

/etc/nginx/sites-available/default

```
1  server {
2      listen 80 default_server;
3
4      location /health {
5          add_header Content-Type text/plain;
6          return 200 'OK';
7      }
8  }
```

TECHNICAL NARRATIVE

- **검증 방식: B 채택 (API 엔드포인트)**
  단순 정적 HTML 파일 서빙보다 현대 클라우드 인프라 연동에 **표준화된 헬스체크 방식** 채택.

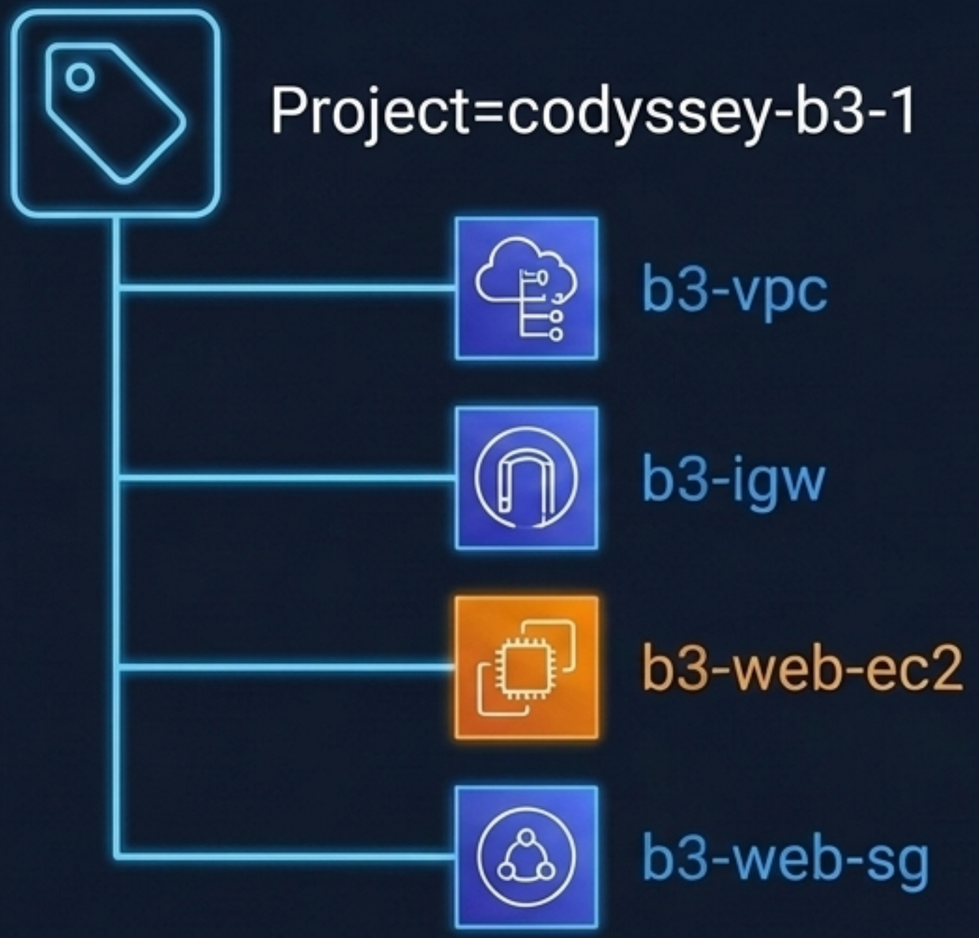
- **엔지니어링 근거 (Lightweight & Fast)**
  별도의 백엔드 애플리케이션(Node.js, Python 등) 구동 없이 **Nginx 커널 단에서 직접 HTTP 200 상태** 코드를 생성하여 오버헤드 최소화.
  ALB(로드밸런서) 자동화 검증에 최적화됨.

- **자동화 구성**
  인스턴스 프로비저닝 시 **user-data.sh** 스크립트를 통해 Nginx 기본 설정 파일을 동적으로 덮어쓰도록 설계하여 배포 자동화 달성.

Gemini Notebook

[Q2-4] 실습 리소스를 추적/정리하기 위해 어떤 기준(태그, 이름 규칙, 체크리스트)을 사용했는지 설명할 수 있는가?

VISUAL EVIDENCE



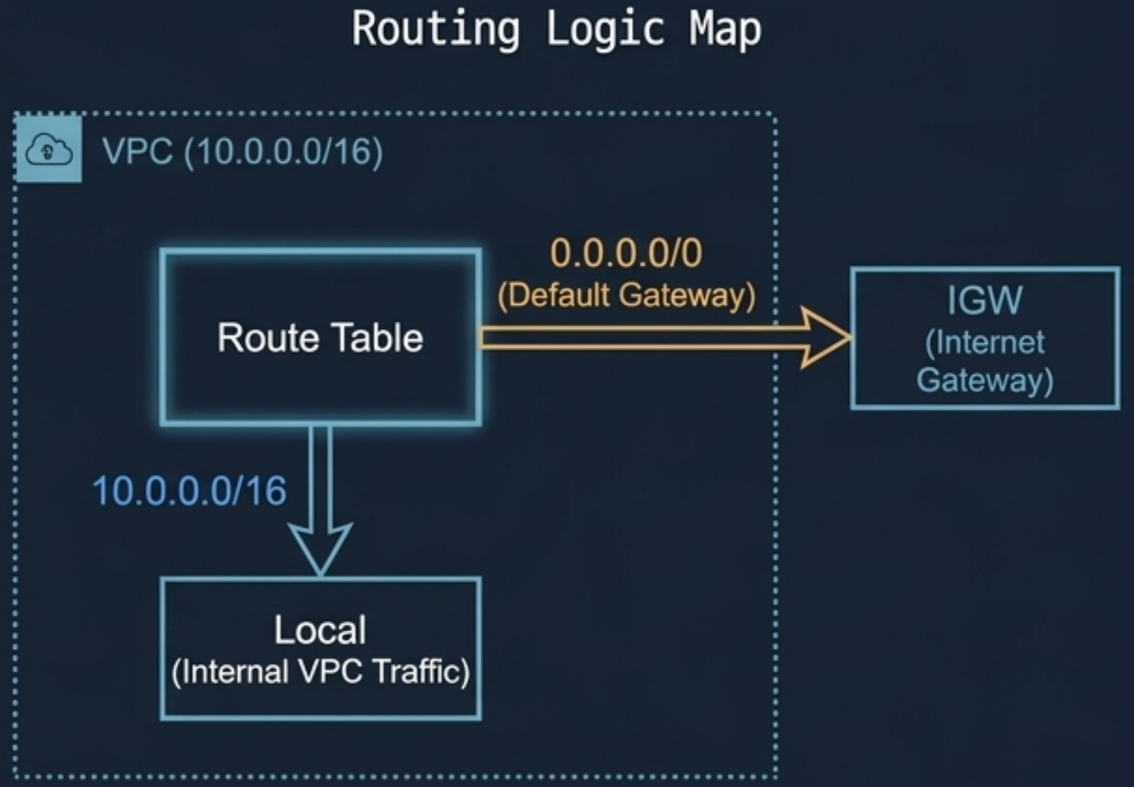
TECHNICAL NARRATIVE

- **3중 추적 거버넌스 체계**
  비용 누수 방지 및 다수 작업자 환경에서의 자원 격리 식별을 위한 엄격한 규칙.
- **전역 태깅 전략**
  모든 리소스에 Project=codyssey-b3-1 메타데이터 부여. AWS CLI(--filters)를 통한 자원 일괄 검색 및 추적 가능.
- **일관된 명명 규칙 (Naming)**
  Name 태그에 b3- 접두사를 강제하여 콘솔 UI에서의 혼동을 원천 차단.
- **체크리스트 문서화**
  docs/cleanup-checklist.md에 프로비저닝된 실제 자원 고유 ID를 기록.
  라이프사이클 관리를 위한 의존성 트리 기반 삭제 절차 수립.

Gemini Notebook

[Q3-1] Public Subnet Route Table의 기본 경로(0.0.0.0/0 → IGW)가 필요 이유를 설명할 수 있는가?

VISUAL EVIDENCE



TECHNICAL NARRATIVE

- **최장 일치 우선 원칙 (Longest Prefix Match)**
  내부 통신(10.0.0.0/16 -> local) 외에, 목적지를 특정할 수 없는 모든 알 수 없는 외부 패킷을 인터넷으로 내보내기 위한 **'기본 게이트웨이'** 역할.

- **Public Subnet의 AWS 정의**
  단순히 공인 IP 할당 유무가 아니라, 라우팅 테이블에 명시적으로 0.0.0.0/0 → IGW 경로가 등록되어 있는지가 Public 망의 유일한 판단 기준.

- **경로 누락 시의 결과**
  해당 규칙이 없으면 외부 클라이언트 인입 패킷에 대한 응답 패킷이 길을 찾지 못해 커널 네트워크 레벨에서 즉시 Drop 처리됨.

Gemini Notebook

[Q3-2] Security Group과 IAM의 책임 범위 차이와 "최소 권한"의 필요성을 설명할 수 있는가?

VISUAL EVIDENCE

Comparison Matrix

Security Group (데이터 평면)	IAM (제어 평면)
- 통제 대상: Network Traffic (IP, Port, Protocol)	- 통제 대상: AWS API Access & 조작
- 적용 단위: ENI (네트워크 인터페이스)	- 적용 단위: Users, Roles, Identity
- 본질적 질문: "어느 IP가 서버로 들어올 수 있는가?"	- 본질적 질문: "누가 ec2:RunInstances API를 호출할 수 있는가?"

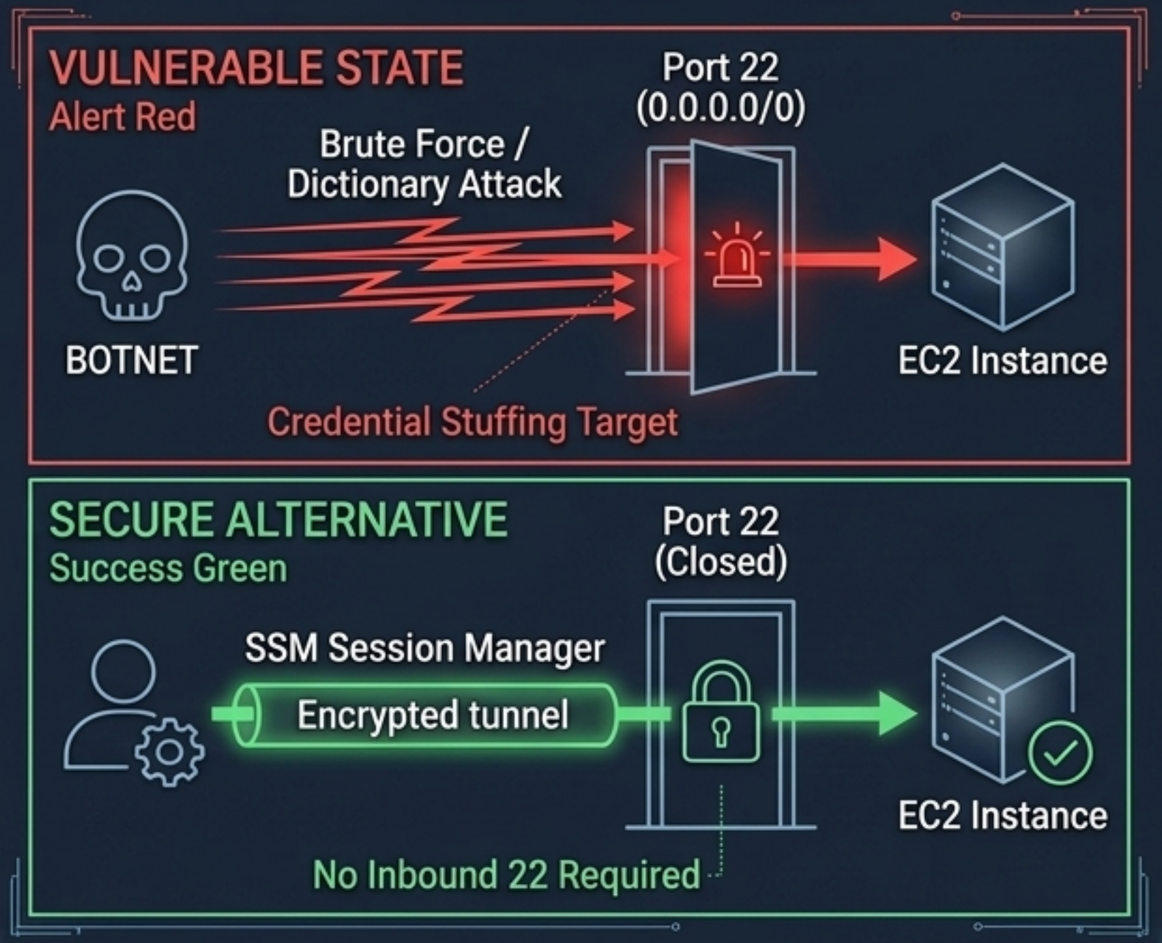
TECHNICAL NARRATIVE

- **역할의 이중 분리**
  네트워크 패킷 방화벽(SG)과 인프라 인가 제어(IAM) 평면을 물리적으로 분리하여 심층 방어.
- **최소 권한의 원칙** (Least Privilege)
  개발용 AdministratorAccess 부여는 치명적 보안 안티패턴. 실습 목적에 맞는 단일 서비스(EC2, VPC) 권한만 부여.
- **피해 반경(Blast Radius) 통제**
  인라인 정책으로 최소화 시, 자격증명(Access Key)이 외부에 유출되더라도 공격자가 타 서비스(RDS 파괴, S3 데이터 탈취)를 조작할 수 없도록 격리.

Gemini Notebook

[Q3-3] SSH(22) 또는 DB 포트를 0.0.0.0/0 로 열면 안 되는 이유와 대안을 설명할 수 있는가?

VISUAL EVIDENCE



TECHNICAL NARRATIVE

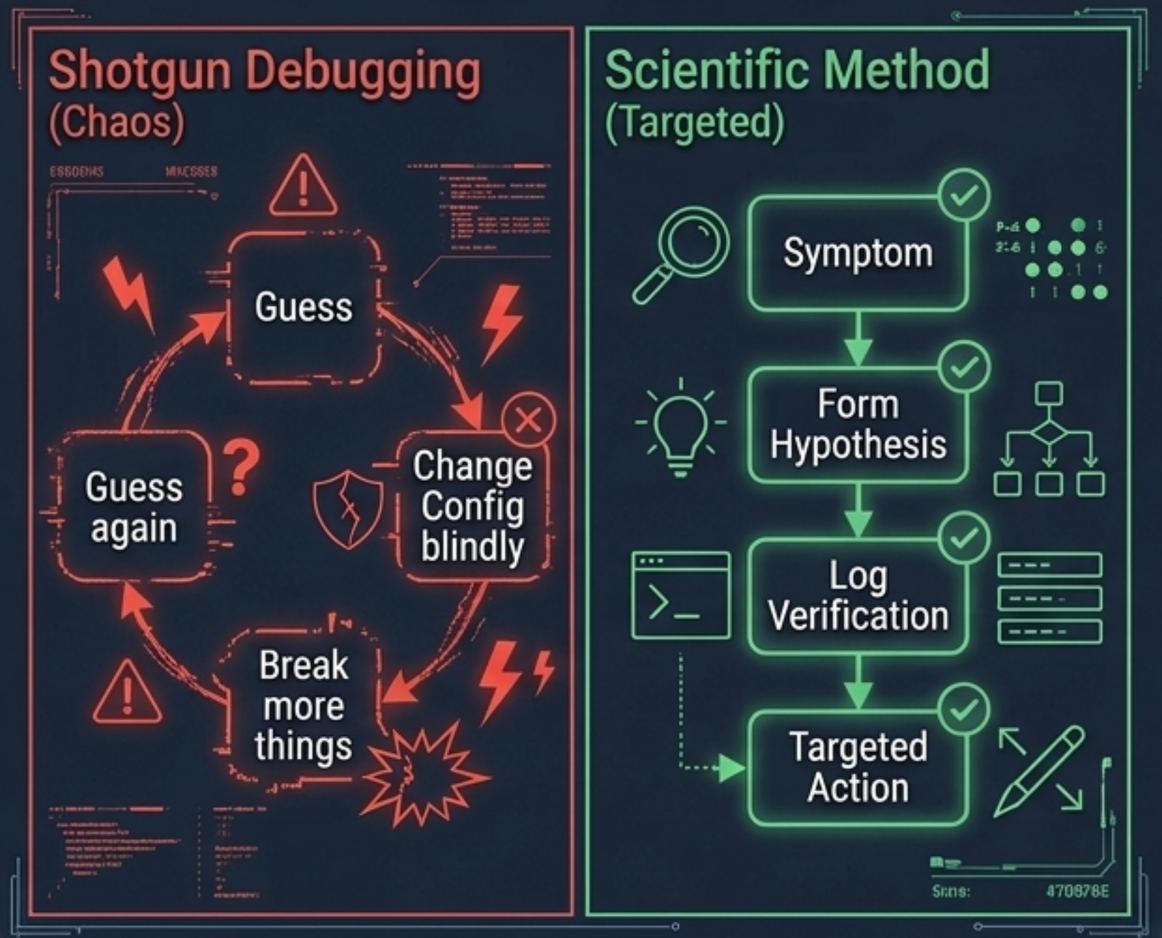
- 치명적 위협 (0.0.0.0/0 개방 시)
  24시간 스캐닝하는 봇넷의 크리덴셜 스터핑(Credential Stuffing) 타겟.
  수 분 내 인스턴스 장악 및 내부망 수평 이동(Lateral Movement) 공격의 교두보 전락.

- 엔터프라이즈 권장 대안 아키텍처
  1. 관리자 IP 격리: 특정 공인 IP(/32)만 화이트리스트 처리 (본 실습 적용 방식).
  2. AWS Systems Manager (SSM): 인바운드 22번 포트를 완전히 닫고, 아웃바운드 HTTPS 에이전트 통신으로 안전한 셸 원격 접속.
  3. Bastion Host: 프라이빗 서브넷에 자원 배치 후 점프 서버 혹은 VPN 이중화 통제.

Gemini Notebook

[Q3-4] 트러블슈팅에서 "가설 → 검증" 순서를 유지한 이유와, 활용 방법을 설명할 수 있는가?

VISUAL EVIDENCE



TECHNICAL NARRATIVE

- **추측 기반 변경의 위험성**
  로그나 데이터 규명 없이 무작정 '보안 그룹을 전체 개방해보자' 식의 임의 대응은 시스템 안정성을 훼손하고 새로운 보안 취약점을 양산함.

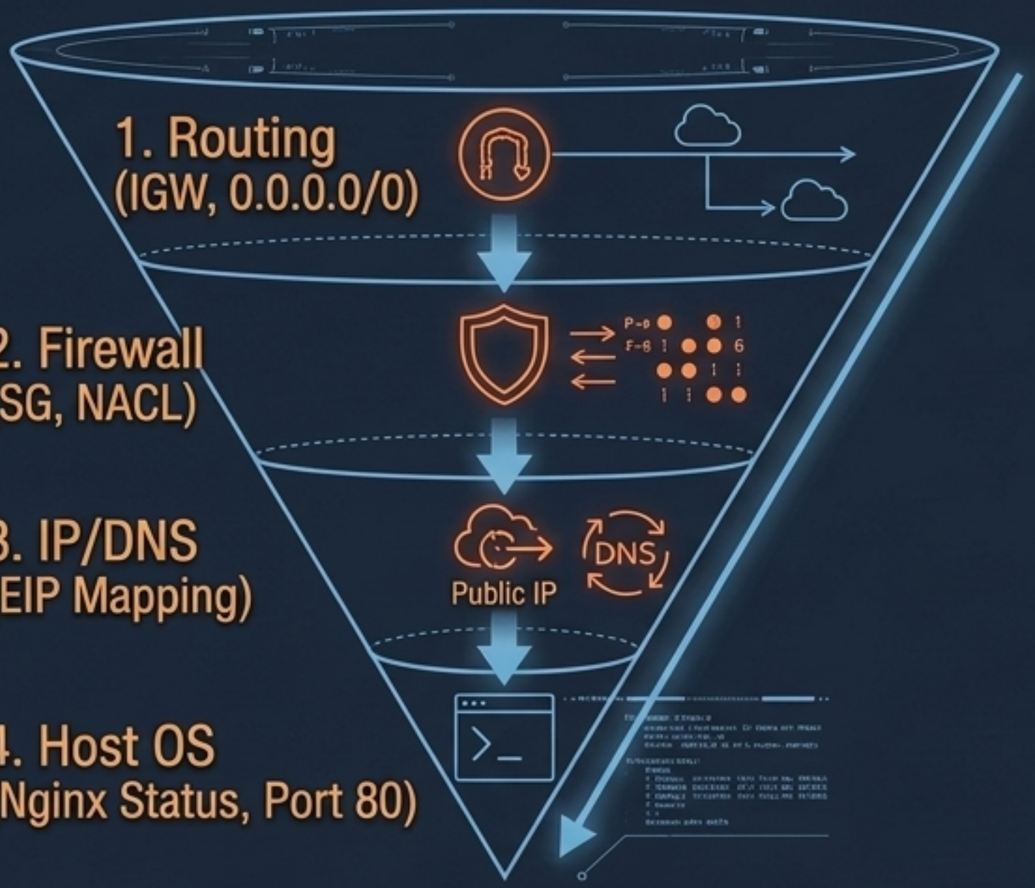
- **공학적 문제 해결 프로세스**
  에러 증상 → 가설 도출 → 로그/데이터 검증 → 국소적 조치의 사이클 엄수.

- **프로젝트 실제 활용 사례**
  에러: 인스턴스 생성 시 InvalidParameterCombination 발생.
  가설: 해당 리전의 프리티어 타입이 t2.micro가 아닐 것이다.
  검증: CLI로 free-tier-eligible=true 필터링 조회.
  조치: 지원되는 t3.micro로 코드 교체하여 논리적 해결.

Gemini Notebook

[Q4-1] 외부 접속 장애 시, 어떤 순서로 점검하는지 설명할 수 있는가?

VISUAL EVIDENCE



TECHNICAL NARRATIVE

- **외부망 통신 단절 진단 (Outside-In)**
  광역 네트워크 경계에서 시작하여 호스트 내부 프로세스로 좁혀 들어가는 논리적 진단 체계.
- **1계층 (네트워크 라우팅)**
  VPC에 IGW가 정상 연결되었는지, 서브넷 기본 경로가 정확한지 확인.
- **2계층 (보안 경계)**
  Security Group 인바운드 80 포트 허용 여부 및 NACL 차단 규칙 점검.
- **3계층 (접근 경로)**
  인스턴스의 공인 IPv4 주소 유실 여부 확인.
- **4계층 (서버 데몬)**
  systemctl status nginx 서비스 가동 상태 점검. Port 80 바인딩 확인 및 /var/log/cloud-init-output.log 내 에러 추적.

Gemini Notebook

[Q4-2] IAM 권한 부족 에러(AccessDenied) 발생 시, 최소 권한 범위를 찾는 방법은?

VISUAL EVIDENCE

```
{
  "eventSource": "ec2.amazonaws.com",
  "eventName": "CreateRoute",
  "errorCode": "AccessDenied",
  "errorMessage": "You are not authorized to
perform this operation."
}
```

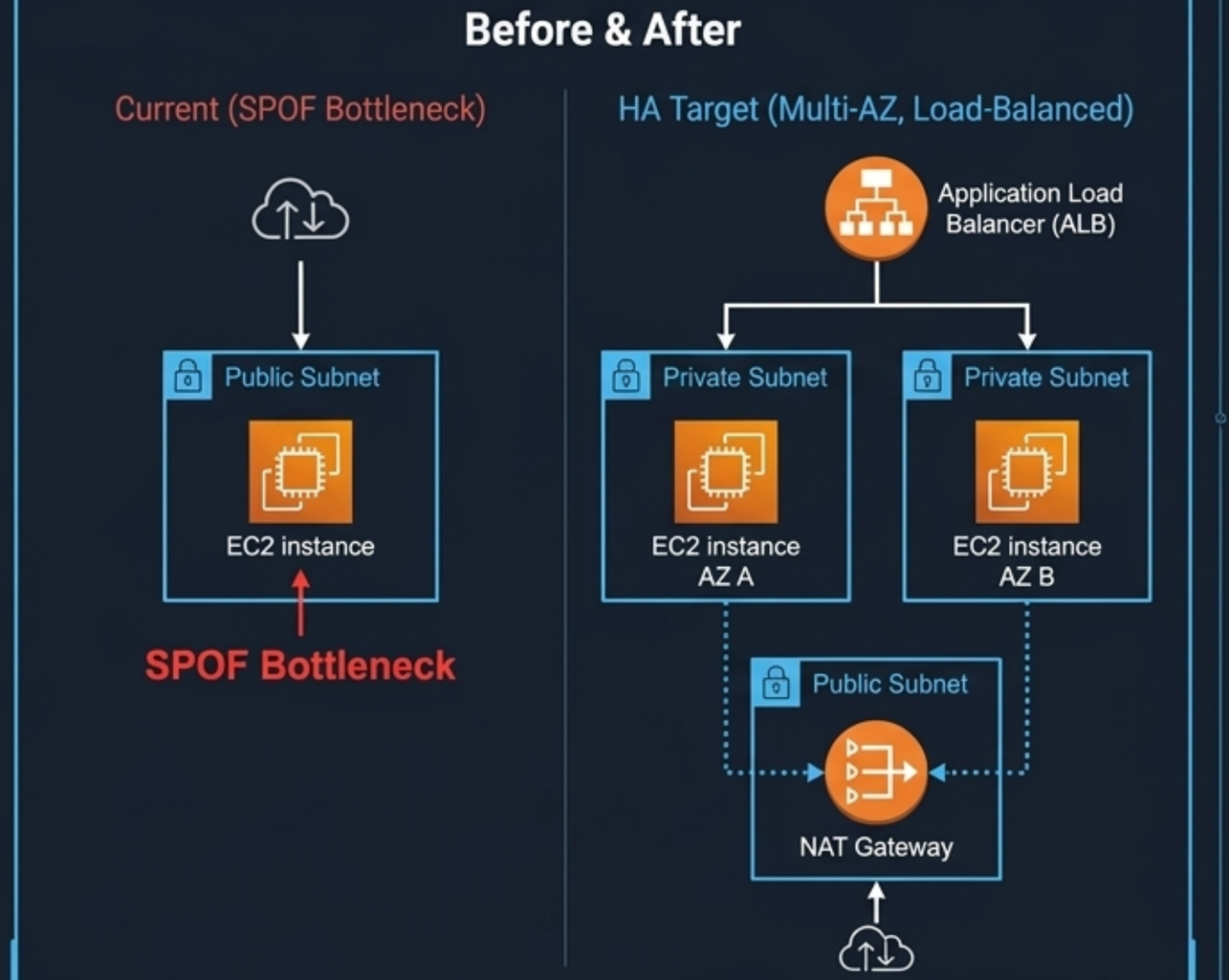
TECHNICAL NARRATIVE

- **보안 안티패턴 경계**
  에러 회피를 목적으로 와일드카드(ec2:*)나 AdministratorAccess를 즉흥적으로 부여하는 행위는 엄격히 금지.
- **최소 권한 추적 4단계 프로세스**
  1. **CLI 에러 디코딩:** 터미널 실패 메시지에서 거부된 구체적 액션 문자열 추출.
  2. **CloudTrail 로그 분석:** 이벤트 기록에서 AccessDenied 필터링 후 요청 파라미터 역추적.
  3. **정책 시뮬레이터:** 배포 전 IAM Policy Simulator로 권한 동작의 정합성 사전 검증.
  4. **점진적 인라인 추가:** 누락된 단일 액션 스트링(예: ec2:CreateRoute)만 JSON 정책 배열에 추가하여 재시도.

Gemini Notebook

[Q4-3] 트래픽 증가로 인스턴스를 늘릴 때, 현재 구조의 병목과 확장 아키텍처는?

VISUAL EVIDENCE



TECHNICAL NARRATIVE

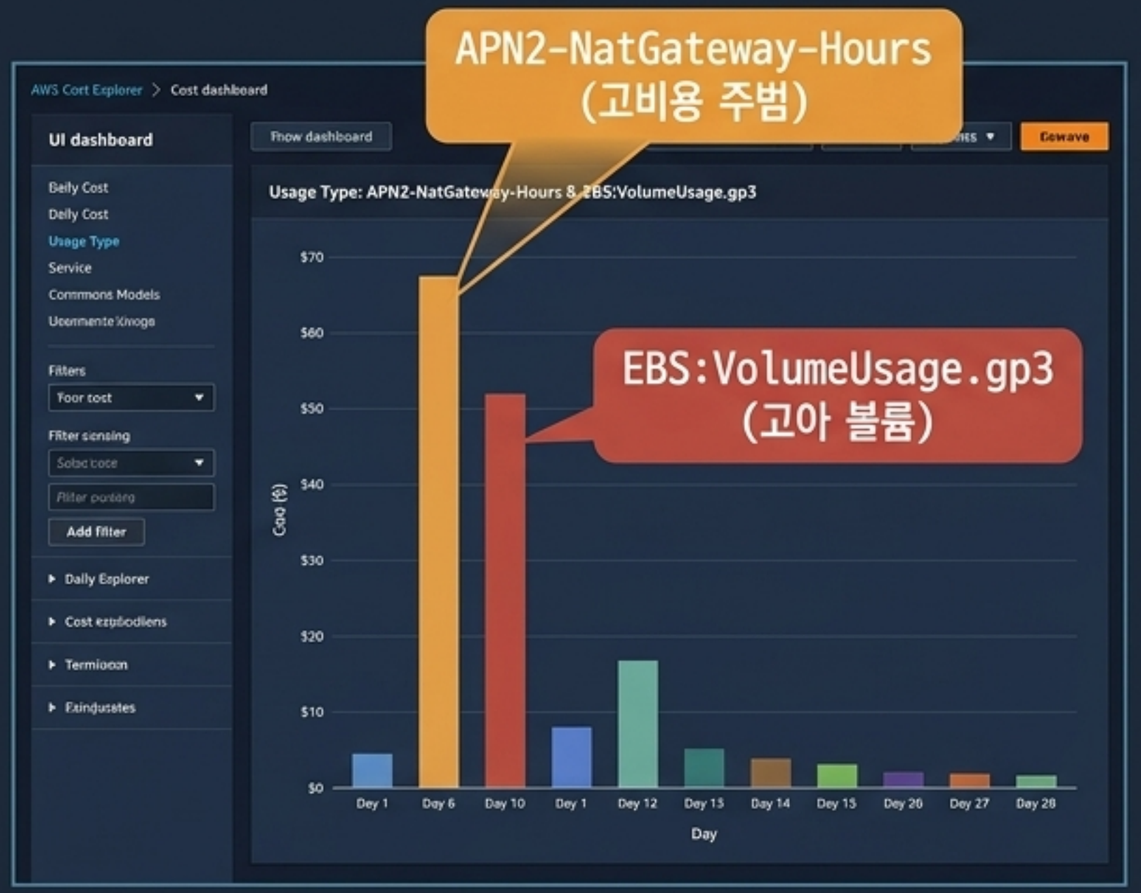
- **현재 아키텍처의 병목 (SPOF)**
  단일 인스턴스 또는 단일 가용영역 장애 시 서비스 전체 중단 발생. 단일 IP 직접 결합으로 부하 분산 불가.

- **고가용성(HA) 아키텍처 확장 설계**
  1. **ALB 전면 배치**: 다중 AZ에 걸쳐 트래픽을 분산하고 무인 상태 헬스체크 수행.
  2. **Private 격리 및 SG Chaining**: EC2를 프라이빗 서브넷으로 은닉하고, 보안 그룹 인바운드를 오직 'ALB의 방화벽 ID'로만 제한하여 네트워크 보안 극대화.
  3. **NAT Gateway 연동**: 프라이빗 망 인스턴스의 아웃바운드 패키지 업데이트 지원.

Gemini Notebook

[Q4-4] 예상치 못한 비용 발생 시, 의심 리소스 및 추적/정리 방법은?

VISUAL EVIDENCE



TECHNICAL NARRATIVE

- Top 4 숨은 과금 주범 탐지
  1. **방치된 NAT Gateway**: 생성 즉시 시간당 고정 비용 및 데이터 요금 발생 (가장 치명적).
  2. **미사용 EIP**: 인스턴스 종료 후 해제(Release)하지 않고 계정에 남겨둔 유휴 공인 IP.
  3. **고아 EBS 볼륨**: DeleteOnTermination=false 속성으로 인해 남겨진 볼륨.
  4. **타 리전 자원**: 기본 리전(us-east-1 등)에 남겨진 방치된 테스트 인프라.
- FinOps 기반 추적 및 정리 프로세스

  비용 식별: Cost Explorer(서비스/사용유형 그룹화) 분석.

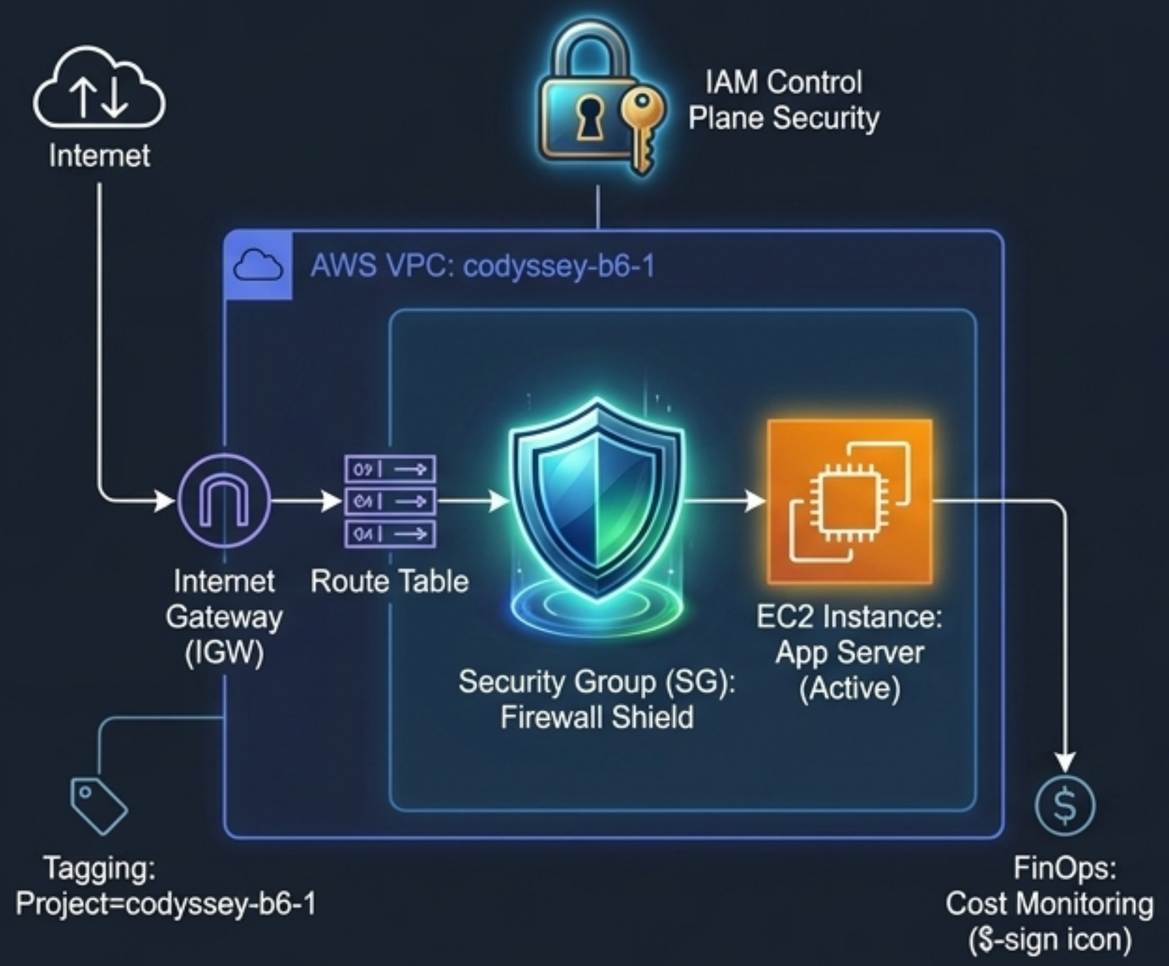
  강제 삭제: CLI 및 Tag Editor를 통한 미사용 자원 전수 검색 및 제거.

  재발 방지: AWS Budgets 기반 임계치 도달 경보 설정.

Gemini Notebook

Synthesis: The B3-1 Infrastructure Blueprint

VISUAL EVIDENCE



TECHNICAL NARRATIVE

- **네트워크 격리 (Network Isolation)**
  VPC와 서브넷 라우팅을 통한 정확한 트래픽 제어 및 외부 접점 통달.
- **엄격한 접근 제어 (Zero Trust Security)**
  데이터 평면(Security Group)과 제어 평면(IAM)을 아우르는 최소 권한 원칙의 완벽한 구현.
- **운영 회복력 (Operational Resilience)**
  API 엔드포인트 헬스체크 자동화, 체계적 OSI 계층 진단 방법론, 그리고 역순 자원 정리를 통한 FinOps 라이프사이클 관리 역량 입증.
- **엔지니어링 결론**
  단순한 가상 머신 배포를 넘어, 엔터프라이즈 레벨로 확장 가능한 클라우드 인프라스트럭처의 가장 견고한 기반 완성.

Gemini Notebook